



BSIT PROJECT DEVELOPMENT CHECKLIST

Group Name	WatchDogs
Project Title	WIMS-BFP: A Secured Web Offline-First Incident Monitoring System with Explainable AI for Threat Interpretability in the Bureau of Fire Protection
Group Members	Cabrales, Nathan Josua C. Camama, Earl Justin P. Dela Cruz, Red Gabrielle A. Tendero, Guinevere T.

SPECIFIC MODULES/TASKS	PERCENTAGE	REMARKS
MODULE 1: AUTHENTICATION AND ACCESS CONTROL (8%)		
a. User Authentication (2%)		
Login with username and password (min 8 chars, uppercase, lowercase, digit, special char)	0.5%	Ok
Multi-Factor Authentication (MFA) via TOTP for System Administrators and National Validators	0.5%	OK
Account lockout after 5 consecutive failed login attempts	0.5%	
Automatic session timeout after 30 minutes of inactivity	0.5%	OK
b. Password Management (2%)		
Reset password via secure email link with one-time token (expires in 15 minutes)	0.7%	
Change password for authenticated users with current password verification	0.7%	OK
Enforce strong password policy (8 chars min, history, 90-day expiry for admin roles)	0.6%	OK
c. Role-Based Access Control / RBAC (2%)		
Five (5) distinct user roles: Regional Encoder, National Validator, National Analyst, System Administrator, Citizen	0.5%	Ok
Access permissions enforced through Keycloak Identity Provider	0.5%	Ok
Least privilege principle applied per role	0.5%	Ok
Role assignment and modification restricted to System Administrators	0.5%	Ok
d. Session Management (2%)		
Secure session token generated upon authentication (OIDC)	0.4%	Ok
Session token stored securely in browser (httpOnly, secure, sameSite flags)	0.4%	Ok
Automatic session renewal on activity (up to 8-hour max lifetime)	0.4%	

Force logout on password change or role modification (Backchannel Logout)	0.4%	Ok
Concurrent session detection with option to terminate previous session	0.4%	Ok
MODULE 2: OFFLINE-FIRST INCIDENT MANAGEMENT (10%)		
a. Incident Data Entry (2.5%)		
Regional Encoder creates fire incident reports with all required fields (UUID, timestamp, location, type, narrative, casualties, damage, responders, status)	1%	Ok
File attachment support (jpg, png, pdf, docx; max 10MB each; max 5 attachments; AES-GCM encrypted)	1%	
Client-side form validation with real-time field-level error messages	0.5%	Ok
b. Offline Data Capture and Storage (2.5%)		
Automatic network availability detection via Navigator API	0.5%	
Offline incident data stored in browser IndexedDB (Dexie.js)	0.5%	
Offline records encrypted with AES-256-GCM before local storage	0.5%	
Offline Mode UI indicator displayed to user	0.5%	
Full CRUD operations functional in offline mode	0.5%	
c. Data Synchronization (2.5%)		
Automatic network restoration detection (TanStack Query)	0.5%	
Upload, verify, conflict-check local incidents on reconnect (Background Sync API)	0.5%	
Atomic synchronization per incident (all-or-nothing)	0.5%	
Exponential backoff retry for failed sync (max 5 retries)	0.5%	
User notification of synchronization success or failure	0.5%	
d. Incident Status Tracking (2.5%)		
Incident status lifecycle: Draft, Pending, Validated, Flagged, Rejected	1%	
Status transitions logged with timestamp and user ID	1%	
Regional Encoder view of status change history per incident	0.5%	

MODULE 3: CONFLICT DETECTION AND MANUAL VERIFICATION (8%)		
a. Duplicate Detection (3%)		
Automatic comparison of newly uploaded incidents against central database	1%	
Conflict detection: exact location/time match, fuzzy narrative matching (80% threshold), casualty/damage match	1%	Ok
Flag potential duplicate, generate alert, route to Manual Verification queue	1%	Ok
b. Manual Verification Workflow (3%)		
National Validator flagged incident review queue	0.6%	Ok
Side-by-side record comparison (ID, date/time, location, narrative, casualties, attachments)	0.6%	Ok
Validator actions: Confirm Duplicate, Confirm Unique, Request Revision (Reject w/ reason)	0.6%	Ok
Encoder notification of verification decision via in-app SSE	0.6%	
Encoder clarification capability for flagged incidents	0.6%	Ok
c. Revision and Resubmission (2%)		
Encoder receives revision notification with return reason; edit and resubmit	0.7%	Ok
Resubmitted incident re-enters queue with Resubmitted tag	0.7%	
National Validator views revision history before final decision	0.6%	
MODULE 4: DATA COMMIT AND IMMUTABLE STORAGE (8%)		
a. Commit and Store Process (4%)		
Commit verified incident to central database (FastAPI Dependency Injection)	0.8%	
Append-only PostgreSQL table (no UPDATE/DELETE on committed records)	0.8%	
SHA-256 hash, commit timestamp, and validator ID stored per record	0.8%	
Insert Validated Record transaction sent to Central Database	0.8%	

Central Database responds with Write Result/DB acknowledgment	0.8%	
b. Audit Log Generation (4%)		
Log every commit operation in dedicated System Logs table (partitioned PostgreSQL)	1.5%	
Audit log entries: incident ID, timestamp, validator ID, SHA-256 hash, sync status	1.5%	
Audit logs immutable (append-only, no deletion; PostgreSQL Rule)	1%	
MODULE 5: ANALYTICS AND REPORTING (8%)		
a. Statistical Query Engine (3%)		
National Analyst aggregated data queries via PostgreSQL Materialized Views	1%	
Multi-filter support: date range, incident type, location, casualty severity, damage range	1%	
Analytics views: monthly/quarterly/annual totals, pie chart, heatmap, trend line, top 10 municipalities, avg response time	1%	
b. Query Execution Pipeline (2%)		
Analyst query parameter form submission and processing	0.7%	
Analytics pipeline fetches and aggregates data from Central Database	0.7%	
Statistical trends and reports output generated	0.6%	
c. Report Export (3%)		
Export reports in PDF (WeasyPrint), Excel (.xlsx, Pandas), and CSV formats	1%	
Exported reports include title, filters, charts, summary stats, timestamp, analyst ID	1%	
All report exports logged in audit trail	1%	
MODULE 6: CRYPTOGRAPHIC SECURITY (5%)		
a. Data-at-Rest Encryption (2.5%)		
AES-256-GCM encryption for sensitive incident data fields in Central Database (SQLAlchemy TypeDecorator)	1%	

Encryption applied to narratives, casualty details, property damage estimates, and attachments	1%	
OpenBao key management with 90-day auto-rotation	0.5%	
b. Data-in-Transit Encryption (2.5%)		
TLS 1.3 enforced for all network communication (Nginx/Traefik)	0.7%	
HTTPS enforced for all web traffic	0.6%	
Weak cipher suites disabled (only AES-256-GCM and ChaCha20-Poly1305 allowed)	0.6%	
HTTP Strict Transport Security (HSTS) for all API endpoints	0.6%	
MODULE 7: INTRUSION DETECTION AND NETWORK MONITORING (7%)		
a. Network Traffic Mirroring (2%)		
Docker network traffic monitored by Suricata via virtualized bridge (AF_PACKET)	0.7%	
IDS monitors all inbound/outbound traffic through Nginx Reverse Proxy on VPS	0.7%	
Mirrored traffic includes HTTP/HTTPS, DB queries, file uploads, auth attempts	0.6%	
b. IDS Configuration (2%)		
Suricata deployed as containerized IDS engine with OWASP Top 10 signatures	0.7%	
Custom BFP-specific rules and Emerging Threats ruleset (weekly updates)	0.7%	
IDS generates EVE JSON unstructured logs for detected security events	0.6%	
c. Log Collection and Forwarding (3%)		
Raw security logs forwarded to Qwen2.5-3B AI module on System Administrator request	1%	
Log forwarding via Redis message broker	1%	
Real-time log forwarding with latency under 5 seconds	1%	
MODULE 8: THREAT DETECTION WITH EXPLAINABLE AI / XAI (10%)		
a. Qwen2.5-3B Integration (2.5%)		

Qwen2.5-3B SLM deployed on VPS via Docker with Llama.cpp bindings	1%	
SLM consumes Suricata EVE JSON alerts and FastAPI audit logs on-demand	1%	
Synchronous on-request operation to conserve VPS CPU/GPU resources	0.5%	
b. Suricata-Driven Anomaly Detection (2.5%)		
Behavioral anomaly detection: Impossible Travel, Bulk Deletion (>10/5min), Off-Hours Access (10PM-6AM), Privilege Escalation, Suspicious Query Patterns	1.5%	
Qwen2.5-3B generates XAI narratives with severity levels: Low, Medium, High, Critical	1%	
c. Explainable AI (XAI) Reports (2.5%)		
Human-readable anomaly explanations generated per selected alert	1%	
Each XAI report includes: anomaly description, log evidence, risk assessment, and recommended action	1%	
Reports delivered to System Monitoring dashboard via API on inference completion	0.5%	
d. Human-in-the-Loop (HITL) Validation (2.5%)		
System Administrator reviews all Medium, High, and Critical alerts via card-based UI	1%	
No automatic blocking actions; all responses require admin decision	0.5%	
Admin actions: Confirm Threat, False Positive (dismiss), Request More Info	0.5%	
All HITL decisions logged for audit trail (PostgreSQL JSONB)	0.5%	
MODULE 9: SYSTEM MONITORING AND HEALTH DASHBOARD (7%)		
a. System Health Metrics (3%)		
Monitor container status (FastAPI, PostgreSQL, Suricata, Qwen-AI uptime and health)	0.7%	
VPS real-time CPU and RAM utilization tracking	0.6%	

Database query latency, PWA sync success rate, and network bandwidth metrics	0.6%	
AI on-demand inference latency monitoring	0.5%	
Metrics refreshed every 60 seconds	0.6%	
b. Log Query and Review (2%)		
System Admin log query with filters: date/time range, user ID, severity, event type	0.7%	
Full-text search across log entries (PostgreSQL tsvector with GIN Index)	0.7%	
Paginated query results (50 entries per page)	0.6%	
c. Configuration Management (2%)		
Admin-configurable alert severity thresholds via UI	0.7%	
Configurable session timeout duration and offline storage limit	0.7%	
Configurable AI Response Timeout (max time per inference request)	0.6%	
MODULE 10: COMPLIANCE AND DATA PRIVACY (5%)		
a. Data Privacy Act / RA 10173 Compliance (1.5%)		
Data minimization: collect only necessary fire incident data	0.5%	
Purpose limitation: incident data used only for fire operations and statistics	0.5%	
Individual rights: right to access, rectification, and erasure (soft delete with audit trail)	0.5%	
b. Cloud-Based Data Protection Impact Assessment / DPIA (1.5%)		
DPIA documentation: data processing activities, privacy risks, legal basis, retention periods	0.8%	
Annual DPIA review or upon major infrastructure changes	0.7%	
c. Records of Processing Activities / RoPA (1%)		
RoPA documenting data subjects, personal data categories, purposes, retention, and security measures	0.5%	
RoPA accessible to System Administrator and Data Protection Officer	0.5%	
d. Breach Notification (1%)		

Automated breach notification report with incident details and affected data scope	0.5%	
Immediate DPO and System Administrator notification; NPC assessment within 72 hours	0.5%	
MODULE 11: PENETRATION TESTING AND SECURITY VALIDATION (5%)		
a. Vulnerability Scanning (2%)		
Vulnerability scans using Nmap (network), OWASP ZAP (web app), and sqlmap (SQL injection)	0.7%	
Scans conducted in controlled staging environment mirroring VPS production	0.7%	
Monthly scanning during development; quarterly post-deployment	0.6%	
b. Penetration Testing Scope (2%)		
Auth bypass, privilege escalation, SQL injection, XSS (stored and reflected), CSRF testing	1%	
Sensitive data exposure, Denial of Service (DoS) resilience testing	1%	
c. Remediation and Retesting (1%)		
Severity-classified remediation: Critical (24h), High (7d), Medium (30d), Low (90d)	0.5%	
Retesting after remediation and security audit report documentation	0.5%	
MODULE 12: USER MANAGEMENT AND ADMINISTRATION (5%)		
a. User Onboarding (2%)		
System Administrator creates new user accounts with full name, email, role, and optional contact number	0.5%	
Auto-generated temporary password sent via secure email (Keycloak Execute Actions)	0.5%	
Forced password change on first login (Required Action: Update Password)	1%	
b. User Profile Management (1.5%)		
Users view and update their own profile (full name, email, contact number)	0.8%	

Users cannot modify their own role; only System Administrator can assign roles	0.7%	
c. User Deactivation and Deletion (1.5%)		
Admin soft-deactivates user accounts (Keycloak enabled: false)	0.5%	
Deactivated accounts retained in DB for audit; reactivatable by admin	0.5%	
Hard deletion of user accounts prohibited to preserve audit trail integrity	0.5%	
MODULE 13: NOTIFICATION SYSTEM (5%)		
a. In-App Notifications (2.5%)		
Real-time SSE notifications for: incident status updates, duplicate alerts, verification decisions, security alerts, sync results	1%	
Non-intrusive toast notifications in top-right corner (react-hot-toast)	0.8%	
Notification history panel for all users (Redis List User Inbox)	0.7%	
b. Email Notifications (2.5%)		
Email notifications for: password reset, account lockout, critical security alerts, weekly reports	1.3%	
Professional email templates with BFP branding, subject line, action link, and Jinja2+MJML rendering	1.2%	
MODULE 14: PUBLIC ANONYMOUS INCIDENT SUBMISSION (5%)		
a. Public Submission Endpoint Features (5%)		
Zero-trust public endpoint POST /api/v1/public/report (no authentication required)	0.6%	
Redis rate limiting: 3 requests per source IP per rolling one-hour window	0.6%	
Anonymous submissions stored with NULL encoder_id and PENDING_VALIDATION status	0.6%	
Auto-resolve region_id via PostGIS nearest-centroid query with fallback	0.6%	
HTTP 429 Too Many Requests with Retry-After header on rate limit exceeded	0.6%	

No attachment upload on public endpoint; attachments require authenticated session	0.5%	
No CAPTCHA; rate limiting is sole abuse prevention mechanism	0.5%	
Pydantic schema validation before any database write	0.5%	
RA 10173 data minimization: no PII beyond operationally necessary data collected	0.5%	
MODULE 15: REFERENCE DATA SERVICE (4%)		
a. Reference Data API Features (4%)		
Authenticated read-only API for geographic reference hierarchy	0.6%	
GET /api/ref/regions (region_id, region_name, region_code; optional filter by region_id)	0.6%	
GET /api/ref/provinces (province_id, province_name, region_id; optional filter by region_id)	0.6%	
GET /api/ref/cities (city_id, city_name, province_id; optional comma-separated province_id filter)	0.6%	
Authentication required via any valid WIMS user role for all reference endpoints	0.6%	
Row-level security: Regional Encoder/Validator see own region only; National Analyst/Admin see all	0.5%	
No write operations on reference data exposed via API	0.5%	
Reference data sourced exclusively from wims.ref_regions, wims.ref_provinces, wims.ref_cities	0.4%	

Approved by:


MR. KIRK ALVIN AWAT
 Project Mentor